

Cloud Services Requirements

Offeror/Contractors proposing solutions that include cloud services must respond to the questions included in this document. The purpose of this document is to gain the necessary information from the Offeror/Contractor to fully understand and evaluate the cloud service being proposed.

Offeror/Contractor shall describe if any part of the proposed cloud service is provided by another third party or subcontractor. The ability of each subcontractor to meet these Cloud Services Requirements must be incorporated into this document. Offeror/Contractor may add a separate attachment or denote responses as "Offeror/Contractor" or "Name of Subcontractor".

If using links in Offeror/Contractor Response column, please provide specific reference point that addresses the question.

REQ #	Category	Question	Offeror/Contractor Response
1	General	Offeror/Contractor shall provide an overview of the proposed cloud service. Please list the solution components, hosting environments, as well as the service organization and subservice organizations operating all aspects that are a part of the overall proposed solution. • Solution Component(s) – SKU/Product Titles and/or	Solution Component(s) The product components of our solution consist of four sector-specific SaaS products. These are FinSecure, HealthGuard, RetailMax, and GovSolve for finance, healthcare, retail, and government clients. The application layers we use include a presentation layer with a user interface and API gateway, a business logic layer with microservices, authentication, and data processing and storage with SQL and NoSQL. We use network and platform components involve VLANs, ACLs, VPNs, SSH, and SFTP. We have security and compliance across all products and environments using IAM, MFA, RBAC, ABAC, MAC, SIEM, EDR,

		Resources utilized by solution provider • Solution Environment(s) – Which public cloud provider, which private cloud stack, and/or who's datacenter for traditional hosting of components. • Solution Operator(s) – Organizational name of the Service Organization and any Subservice Organizations actively supporting the proposed solution.	IDPS, antivirus, anti-malware, TLS 1.3, and AES-256. We deliver and operate using GitLab, Jenkins, Docker, OpenVPN, VS Code, SonarQube, Terraform, SNS, and Lambda Solution Environment(s) Our solution uses the Amazon Web Services (AWS) infrastructure in the US East (N. Virginia, us-east-1) region with ELB, WAF Shield Advanced, Inspector, KMS, Cloudfront, and RDS encryption using multiple Availability Zones for high availability and disaster recovery. The supporting stack we use has production and services on AWS including development, test, staging, and production networks. Additionally, the stack includes AWS WAF, AWS Shield Advanced, Amazon Inspector, Amazon RDS, AWS KMS, AWS S3, AWS ELB, and AWS CloudFront. Solution Operator(s) The organizational name of the service organization is FinHealthGov Retail Solutions Inc. The subservice organization is Amazon Web Services (AWS). The supporting environment is AWS US East (N. Virginia), us-east-1.
2	General	Offeror/Contractor shall describe if the proposed cloud service is a dedicated single tenant or shared (multi-tenant) cloud solution. If multi-tenant, Offeror/Contractor shall describe the security controls to isolate the tenants.	We use a shared (multi-tenant) solution to keep client data separated and secure while serving many customers on a shared AWS infrastructure. Our platform components include AWS cloud-based data center, AWS us-east-1 region, ELB, WAF, RDS, S3, KMS, and CloudFront to logically separate tenants instead of a fully dedicated environment per customer.
3	General	Offeror/Contractor shall describe Service Level Agreements (SLAs)	Availability: 99.9% monthly uptime for production service excluding scheduled maintenance, customer-caused outages,

		included with the proposed Cloud Service that identify both the services required and the expected level of service including, but not limited to, the following: • Availability • Performance • Disaster Recovery expectations (RTO/RPO) • Pandemic Recovery expectations • Location of the data Primary/Secondary (if applicable?) • Access to the data • Portability of the data (ability to move data to a different hosting provider) • Metrics used to measure the service, e.g. service level objectives	and third-party internet failures. The maintenance windows will be no more than 4 hours per month providing notice of at least 5 business days. Performance: 95% of application requests will be responded under 2 seconds for standard user transactions. 95% of API calls will be responded to in under 500ms with normal operating conditions. Throughput will scale automatically during peak hours and monitoring tools will be used for monthly reports. Disaster Recovery Expectations: 4 hour RTO, 15 minute RPO, continuous replication for critical data, daily full backups, and 1 full disaster recovery test per year with quarterly tabletop exercises. Pandemic Recovery: A pandemic or an equivalent disruption is covered by fully remote administration and support within 1 business day. Critical roles have documented cross-training and backup coverage. Support services will remain available in remote work scenarios. Full support operations is restored within 5 business days of disruption. Data Location: AWS US East (N. Virginia) us-east-1 replicated in AWS regions for disaster recovery where customer data remains. Access to data: 24/7 data access for customers subjected to maintenance and security controls. Our administrator access managed with MFA, role-based access, and logged sessions. We provide data export requests within 5 business days for
--	--	---	--

			standard requests. Customers can audit logs and access records relevant to their tenant, limited by security and legal limitations. Portability: Data is exportable in CSV, JSON, and PDF where applicable. We provide migration support for 30 days after terminal or non-renewal. Customer data can be securely deleted from our systems within 30 days after an export and contract end. We do not have a proprietary format that prevents migration of core customer records that can be given to another provider.
4	General	Offeror/Contractor shall describe controls for record retention and data destruction of data past retention period in accordance with ITP-SEC019 Policy and Procedures for Protecting Commonwealth Data and ITP-SEC015 Data Cleansing Policy. Offeror/Contractor shall describe how they will confirm that the data has been destroyed. Commonwealth preference is certified letter(s) of confirmation at end of contract and quarterly for aged data.	Record Retention Controls: We hold a record retention schedule tied to each record type based on the sensitivity of the data and regulatory requirements. Business owners and IT know when data can be retained, archived, or disposed because we hold ownership and accountability for each record category. Retention actions of access, review, archival, and disposal decisions are audit logged. Data Destruction Controls: Data that is no longer needed will be sanitized and destroyed. Appropriate sanitization methods will be used for each media type. Destruction will be documented, showing who, what, where, when, and how data was destroyed. Confirmation Controls: A certified letter of confirmation is used to confirm destruction at the end of a contract. A quarterly destruction attestation for aged data shows what was destroyed and what remains.

5	General	Offeror/Contractor shall, upon contract expiration or at any other time at the written request of the Commonwealth, return to the Commonwealth all of its data (and all copies of this information) in a format agreed to by the Commonwealth. Offeror/Contractor shall provide method of export of Commonwealth data during the contract term.	Method of Export: CSV or JSON files will be exported for structured records. PDF files will be exported for human-readable reports or supporting documents. Documents will be exported through a secure portal with encrypted transfer instead of email or ad hoc file sharing. Encryption will be performed in transit and at rest, along with access controls, audit logging, and approval workflow for sensitive exports.
6	General	Offeror/Contractor shall provide current FedRamp Status (ready, in process, authorized, not yet applied) and level (Low, Moderate, or High). If FedRamp status is "authorized," Offeror/Contractor shall provide details for the following: • Service Model • Deployment Model • Impact Level • Independent Assessor • Authorization Date • Service Description • Agencies using this service	Service Model: Software as a Service, where the service being provided depends on the industry being serviced. Deployment Model: Public cloud, multi-tenant, and AWS-hosted. Impact Level: Moderate Independent Assessor: FedRAMP-recognized 3PAO Authorization Date: April 24, 2026 Service Description: Secure multi-tenant SaaS for regulated sectors. Agencies using this service: DoD, DHS, GSA, FEMA, NASA, the Department of Veterans Affairs, the Department of Energy, and the Department of Justice.

7	General	Offeror/Contractor shall indicate if the following NIST guidelines are adhered to: • NIST SP 800-53 Assessing Security and Privacy Controls in FIS organizations • NIST SP 800-63 Digital Identity Guidelines • NIST SP 800-92 Guide to Computer Security Log Management • NIST SP 800-144 Guideline on Security and Privacy in Public Cloud Computing • NIST SP 800-145 NIST Definition of Cloud Computing and Deployment Models • NIST SP 800-146 NIST Cloud Computing Synopsis and Recommendations Please also indicate if other NIST guidelines apply to the proposed cloud service.	NIST SP 800-53: Yes, reflected. We use extensive security and privacy controls including: IAM, MFA, RBAC, logging, encryption, SIEM, incident response, and audit trails. NIST SP 800-63: Yes, reflected. Our cloud solution uses OAuth 2.0, OpenID Connect, MFA, and identity/authorization services Our cloud solution maps well to digital identity and authentication guidance. NIST SP 800-92: Yes, reflected. Our company uses centralized log collection, audit trails, and SIEM-based monitoring Our controls are consistent with computer security log management guidance. NIST SP 800-144: Yes, reflected. Our solution is a public-cloud deployment on AWS We provide cloud security, shared-responsibility-style controls, and data protection. NIST SP 800-145: Yes, reflected. We have an AWS-hosted SaaS offering and multi-tenant cloud deployment align We adhere to NIST's cloud computing definition and deployment-model concepts. NIST SP 800-146: Yes, reflected. Our architecture shows a cloud synopsis and recommendation style approach: segmented environments, multi-tier architecture, cloud storage, load balancing, scaling, and security-by-design.

8	Regulatory Compliance Verification	Offeror/Contractor shall indicate if the proposed cloud service is subject to any of the following laws: • CJIS and CHRIA for criminal history data • HIPAA for health-related data • IRS Pub 1075 and SSA for federal protected data • PCI-DSS for financial data Offeror/Contractor shall provide certifications or letters of attestation for any deemed applicable to the proposed cloud service.	HIPAA: Applicable because we offer healthcare as a SaaS product where we handle patient data, HIPAA-compliance data handling, access controls, audit trails, encryption, and secure data handling. PCI-DSS: Applicable because our finance and retail products use PCI-DSS alignment for payment and financial processing. CJS and CHRIA: Applicable when storing or processing criminal justice or criminal history information for an agency. IRS Pub 1075 / SSA: Applicable when handling Federal Tax Information or Social Security Administration protected data for government use cases.
9	Access to Commonwealth specific systems, data, and services (ITP-SEC040 CSR-L3)	Offeror/Contractor shall limit access to Commonwealth-specific systems, data and services and provide access only to those staff, located within CONUS, that must have access to provide services proposed. Offeror/Contractor shall describe their support model including after-hours support. Offeror/Contractor shall indicate if any support mechanism or staff are located outside of CONUS and describe in detail the offshore	Support Model: We provide standard support between Monday and Friday during normal business hours for general questions, service requests, and non-urgent issues. We provide after-hours support with 24/7 on-call coverage for production outages, security incidents, and service degradation. Critical issues go immediately to engineering, security, and operations using severity-based routing and escalation. We provide customer channels using a support portal and email for routine tickets, with an additional phone or emergency line for urgent after-hours incidents.

		access required to provide services proposed. a) If OCONUS, Offeror/Contractor shall indicate if logging is enabled to capture the date, time, named user, and nature of the offshore access (i.e., read-only or modify) and whether such logs are maintained and preserved according to applicable data protection law(s) and industry best practice standards. b) If OCONUS support is required, Offeror/Contractor shall indicate whether offshore staff are direct employees or are subcontracted staff. c) If OCONUS, Offeror/Contractor shall indicate whether offshore staff have direct access to Commonwealth data or if the Commonwealth must grant access? If Commonwealth must grant access, please provide request and approval process flow. d) Please describe any additional protections in	CONUS: Our company is CONUS as our headquarters is in Virginia, USA. Our cloud environment is hosted in AWS US East which is within the United States. OCONUS: We log all offshore access events with the date/time stamp, user identity, source/location, data set accessed, and access type. We record successful and failed access attempts and send logs to a centralized, secure log repository with restricted access. Our logs are kept according to the legal retention period with policies defining how each log class is retained. Logs are encrypted at rest and in transit and have role-based access controls. Outdated logs are archived according to policy and other records are preserved for legal holds, audits, or incident investigations. Offshore staff will be direct employees as we control the hiring, supervision, and access of those offshore staff. Offshore personnel shall have no direct access to Commonwealth data unless and until the Commonwealth grants written approval for a named individual, a defined purpose, and a defined access scope. Access shall be least-privilege, time-limited, logged, and subject to periodic review and immediate revocation when no longer required. Commonwealth data accessed by OCONUS vendor employees and subcontractors shall be subject to additional protections including named-user least-privilege access only, commonwealth-written approval prior to access, mandatory MFA, session logging, device, network, and location restrictions. Additionally, we provide protection with encryption in transit
--	--	--	--

		place with respect to Commonwealth data that vendors employees and/or subcontractors would have access to while OCONUS.	and at rest, prohibition on local storage, copying, printing, or removable-media transfer unless expressly authorized, continuous monitoring and alerting for anomalous access, and immediate revocation of access upon role change, contract end, or security concern.
10	Data Hosting (ITP-SEC040 CSR-L4)	Offeror/Contractor shall only host, store, or backup Commonwealth Data in physical locations within CONUS. • Offeror/Contractor shall describe which data centers are intended for use with the proposed cloud service. • Offeror/Contractor shall provide a description of the physical security measures in place within the proposed data centers. Describe both the physical data center access as well as server room and physical host access. Offeror/Contractor shall completely test and apply patches for all third-party	Data Centers Intended for Use: We intend to use AWS data centers in the US East (N. Virginia) region, us-east-1, with multiple Availability Zones for high availability and disaster recovery. We use a single primary AWS-hosted cloud region with resilience provided inside the region. Physical Security: AWS's physical security model includes controlled building ingress points, surveillance and detection systems, professional security staff, MFA for authorized personnel, and escorted visitor access. At the data center and server-room level, access is limited on a least-privilege, need-to-know basis, requests are time-bound and approved, doors are alarmed if forced or held open, and access is logged, monitored, and revoked when no longer needed. Upgrades and Maintenance: Infrastructure, hardware, and software shall be upgraded and patched on an ongoing basis in accordance with secure configuration and change-management procedures. Changes shall be tested prior to production deployment, and customers shall receive advance notice of planned maintenance, release notifications for material changes, and prompt incident notifications for unplanned events.

		software products before release. • Offeror/Contractor shall describe how often the infrastructure, hardware, and software are upgraded, hardened, and patched and what notifications are provided to the customer.	
11	System and Organization Controls (SOC) Reporting (ITP-SEC040 CSR-L5)	Offeror/Contractor shall provide relevant SOC reports, which have been performed by an independent CPA-certified auditor, for the proposed cloud service. Reports should be submitted to the Contract Manager. Link to OPD SEC040B SOC Reporting Procedures SOC 1 TYPE II Report is required under the following conditions:	AWS maintains independently audited SOC 1, SOC 2, and SOC 3 reports for the cloud environment, with the audits performed by Ernst & Young LLP. Our service is most relevant to SOC 2 Type II because it addresses security, availability, confidentiality, and privacy controls.

		• The service organization is hosting financial information that could affect or have a material impact on a Commonwealth agency's financial statements and/or reporting. • Compliance mandate for federal or state audit requirements and/or policy. • A third-party provides financial service(s) (such as, but not limited to, payroll processing, accounts receivable, payable, or collection service). SOC 2 TYPE II Report is required under the following conditions: • The service organization is hosting, handling, or processing Class "C" Classified Records or Closed Records as defined in ITP-SEC019 • Compliance mandated with federal or state audit requirements and/or policy.	
12	Accessibility Standards (ITP-SEC040 CSR-A1)	Offeror/Contractor shall comply with the Accessibility Standards	Accessibility Conformance Report

		in Section 6 of ITP-ACC001 for all provided products and services. • Offeror/Contractor shall submit a completed VPAT using the most current version of the VPAT template for the proposed cloud service(s). ○ The VPAT template should be filled out in its entirety and include testing methodology, conformance level, and remarks for any partially supported or non-supported level. ○ If VPAT(s) are submitted, using an older version of the template, Offeror/Contractor should provide an explanation, as to why the most current version is not being used.	<table><tr><th>Standard / Criterion</th><th>Conformance</th><th>Remarks</th></tr><tr><td>WCAG 2.2 / 1.1.1 Non-text Content</td><td>Supports</td><td>Informative images and icons are intended to have text alternatives; decorative images are ignored by assistive technology.</td></tr><tr><td>WCAG 2.2 / 1.3.1 Info and Relationships</td><td>Supports</td><td>Page structure uses headings, labels, and programmatic relationships to preserve meaning for screen reader users.</td></tr><tr><td>WCAG 2.2 / 1.3.2 Meaningful Sequence</td><td>Supports</td><td>Content is presented in a logical reading order consistent with visual layout.</td></tr><tr><td>WCAG 2.2 / 1.4.1 Use of Color</td><td>Supports</td><td>Color is not used as the sole method to convey meaning or status.</td></tr><tr><td>WCAG 2.2 / 1.4.3 Contrast (Minimum)</td><td>Supports</td><td>Text and interactive controls are designed to meet minimum contrast requirements.</td></tr><tr><td>WCAG 2.2 / 1.4.4 Resize Text</td><td>Supports</td><td>Text can be resized up to 200% without loss of content or functionality.</td></tr><tr><td>WCAG 2.2 / 1.4.10 Reflow</td><td>Supports</td><td>The interface is responsive and intended to reflow at smaller viewport sizes without horizontal scrolling.</td></tr><tr><td>WCAG 2.2 / 2.1.1 Keyboard</td><td>Supports</td><td>Core functionality is operable using a keyboard interface only.</td></tr><tr><td>WCAG 2.2 / 2.1.2 No Keyboard Trap</td><td>Supports</td><td>Users can move focus through and away from interface components without keyboard traps.</td></tr><tr><td>WCAG 2.2 / 2.2.1 Timing Adjustable</td><td>Supports</td><td>Any time-based actions provide user controls to extend or disable time limits where applicable.</td></tr><tr><td>WCAG 2.2 / 2.4.1 Bypass Blocks</td><td>Supports</td><td>Skip navigation and other bypass mechanisms are provided to help users move directly to main content.</td></tr></table>	Standard / Criterion	Conformance	Remarks	WCAG 2.2 / 1.1.1 Non-text Content	Supports	Informative images and icons are intended to have text alternatives; decorative images are ignored by assistive technology.	WCAG 2.2 / 1.3.1 Info and Relationships	Supports	Page structure uses headings, labels, and programmatic relationships to preserve meaning for screen reader users.	WCAG 2.2 / 1.3.2 Meaningful Sequence	Supports	Content is presented in a logical reading order consistent with visual layout.	WCAG 2.2 / 1.4.1 Use of Color	Supports	Color is not used as the sole method to convey meaning or status.	WCAG 2.2 / 1.4.3 Contrast (Minimum)	Supports	Text and interactive controls are designed to meet minimum contrast requirements.	WCAG 2.2 / 1.4.4 Resize Text	Supports	Text can be resized up to 200% without loss of content or functionality.	WCAG 2.2 / 1.4.10 Reflow	Supports	The interface is responsive and intended to reflow at smaller viewport sizes without horizontal scrolling.	WCAG 2.2 / 2.1.1 Keyboard	Supports	Core functionality is operable using a keyboard interface only.	WCAG 2.2 / 2.1.2 No Keyboard Trap	Supports	Users can move focus through and away from interface components without keyboard traps.	WCAG 2.2 / 2.2.1 Timing Adjustable	Supports	Any time-based actions provide user controls to extend or disable time limits where applicable.	WCAG 2.2 / 2.4.1 Bypass Blocks	Supports	Skip navigation and other bypass mechanisms are provided to help users move directly to main content.
Standard / Criterion	Conformance	Remarks																																					
WCAG 2.2 / 1.1.1 Non-text Content	Supports	Informative images and icons are intended to have text alternatives; decorative images are ignored by assistive technology.																																					
WCAG 2.2 / 1.3.1 Info and Relationships	Supports	Page structure uses headings, labels, and programmatic relationships to preserve meaning for screen reader users.																																					
WCAG 2.2 / 1.3.2 Meaningful Sequence	Supports	Content is presented in a logical reading order consistent with visual layout.																																					
WCAG 2.2 / 1.4.1 Use of Color	Supports	Color is not used as the sole method to convey meaning or status.																																					
WCAG 2.2 / 1.4.3 Contrast (Minimum)	Supports	Text and interactive controls are designed to meet minimum contrast requirements.																																					
WCAG 2.2 / 1.4.4 Resize Text	Supports	Text can be resized up to 200% without loss of content or functionality.																																					
WCAG 2.2 / 1.4.10 Reflow	Supports	The interface is responsive and intended to reflow at smaller viewport sizes without horizontal scrolling.																																					
WCAG 2.2 / 2.1.1 Keyboard	Supports	Core functionality is operable using a keyboard interface only.																																					
WCAG 2.2 / 2.1.2 No Keyboard Trap	Supports	Users can move focus through and away from interface components without keyboard traps.																																					
WCAG 2.2 / 2.2.1 Timing Adjustable	Supports	Any time-based actions provide user controls to extend or disable time limits where applicable.																																					
WCAG 2.2 / 2.4.1 Bypass Blocks	Supports	Skip navigation and other bypass mechanisms are provided to help users move directly to main content.																																					

			WCAG 2.2 / 2.4.3 Focus Order	Supports	Focus order follows a predictable sequence aligned with the visual layout.
			WCAG 2.2 / 2.4.4 Link Purpose	Supports	Link text is descriptive and communicates destination or action purpose.
			WCAG 2.2 / 2.4.6 Headings and Labels	Supports	Headings and labels are used consistently to identify sections and controls.
			WCAG 2.2 / 2.4.7 Focus Visible	Supports	Keyboard focus is visible on interactive elements throughout the application.
			WCAG 2.2 / 3.1.1 Language of Page	Supports	The language of each page is set programmatically.
			WCAG 2.2 / 3.2.1 On Focus	Supports	Receiving focus does not trigger unexpected context changes.
			WCAG 2.2 / 3.2.2 On Input	Supports	User input does not automatically cause substantial changes without warning or confirmation.
			WCAG 2.2 / 3.3.1 Error Identification	Supports	Input errors are identified clearly and associated with the relevant field.
			WCAG 2.2 / 3.3.2 Labels or Instructions	Supports	Fields include clear labels and instructions where needed.
			WCAG 2.2 / 4.1.2 Name, Role, Value	Supports	UI components expose accessible names, roles, and states to assistive technologies.
			508 Criterion	Conformance	Remarks
			501 Software	Supports	The application is intended to support keyboard access, accessible forms, and screen reader compatibility.

			<table><tr><td>502 Web Content</td><td>Supports</td><td>Web content is designed to align with WCAG-based accessibility expectations.</td></tr><tr><td>503 Functional Performance Criteria</td><td>Supports</td><td>Users can access core workflows without relying on a single sense or specific input method.</td></tr><tr><td>504 Authoring Tools</td><td>Partially Supports</td><td>Administrative or content-entry tools support accessibility, but some third-party editing features may require validation.</td></tr><tr><td>602 Support Documentation</td><td>Supports</td><td>User-facing help and support materials are available in accessible digital formats.</td></tr></table>	502 Web Content	Supports	Web content is designed to align with WCAG-based accessibility expectations.	503 Functional Performance Criteria	Supports	Users can access core workflows without relying on a single sense or specific input method.	504 Authoring Tools	Partially Supports	Administrative or content-entry tools support accessibility, but some third-party editing features may require validation.	602 Support Documentation	Supports	User-facing help and support materials are available in accessible digital formats.
502 Web Content	Supports	Web content is designed to align with WCAG-based accessibility expectations.													
503 Functional Performance Criteria	Supports	Users can access core workflows without relying on a single sense or specific input method.													
504 Authoring Tools	Partially Supports	Administrative or content-entry tools support accessibility, but some third-party editing features may require validation.													
602 Support Documentation	Supports	User-facing help and support materials are available in accessible digital formats.													
13	System Monitoring Audit Logging (ITP-SEC040 CSR-S1)	Commonwealth policy requirements: - Audit logging must be enabled and accessible to the Commonwealth (Information Security Office or designee) - Verbose logging is required - Vendor must have ability to correlate events, create security alerts, and based on severity of event (critical, severe, high-level) send incident notifications to Commonwealth Information Security Officers (ISOs). - Maintain reports online for a minimum of 90 days and archive for a	a) We perform system monitoring and audit logging across our environment with verbose logging and the ability to correlate events across services. Our requirements are addressed through AWS-hosted logging, centralized monitoring, and more in the application and database layers. Additional monitoring happens in the container, API gateway, and more where those components are used. b) Customer-visible logs include security, application, database, and infrastructure audit logs, and Commonwealth ISOs should have direct access or designee access to those logs as required. If direct access is not feasible, access should be provided promptly upon request through a secure, auditable export or portal. c) Our log details include timestamp, user ID, source IP/location, event type, target system/object, action performed, success/failure, before/after values for changes, and associated severity or alert code. d) Dashboards and analytics are provided for Commonwealth ISO use. Features include real-time security monitoring,												

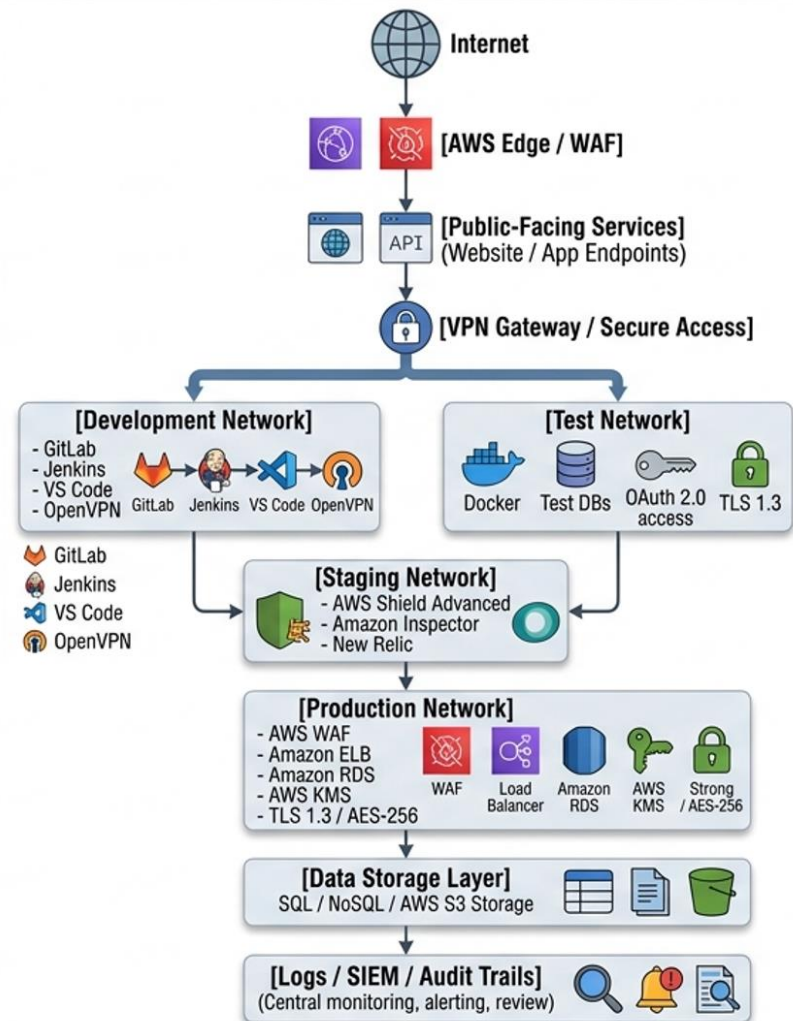
		minimum of 1 year. If the Commonwealth requires longer retention periods, the longer retention requirement takes precedence and should be documented in the SOW. a) Offeror/Contractor shall review and evaluate the system monitoring and audit logging requirements listed in ITP-SEC040 Section 4.2 and describe which apply and how they are being addressed as part of the proposed cloud service. Offeror/Contractor shall also indicate if any additional monitoring and logging is included. b) Offeror/Contractor shall describe which system monitoring and audit logs are available to the customer and indicate how they are made available to the Commonwealth Information Security Officers (ISOs). Please indicate if authorized direct access, available only upon request, or other.	operational alerts, event correlation, and visibility into system and network impact. e) We report monthly which include log-volume summaries, notable incidents, access exceptions, privileged activity, patch/vulnerability status, unresolved alerts, and remediation progress. f) Annual reporting includes a consolidated security posture report, independent vulnerability assessment results, control testing results, incident trends, contingency test outcomes, and remediation status for major findings. g) Our continuous monitoring includes real-time application and infrastructure monitoring, SIEM-driven alerting, log correlation, monthly privileged-access reviews, quarterly alert testing, annual independent vulnerability assessments, and periodic control effectiveness reviews. h) We use scheduled log reviews, quarterly contingency plan tests, incident response tabletop or live exercises, and annual vulnerability scans or independent assessments, with evidence retained for audit. i) Assessment findings and threshold alerts are triaged for severity, then mitigated, transferred, or accepted based on risk appetite, with high-risk items remediated immediately and accepted risks requiring documented approval and expiry dates. j) Access to logs, dashboards, reports, and monitoring outputs are secured with role-based access in a customer portal or SIEM integration, with Commonwealth ISO access granted directly or by request, and all access actions logged.
--	--	--	--

		c) Offeror/Contractor shall provide an example of the logs to show what level of detail is available. d) Offeror/Contractor shall describe if any dashboards and/or analytics are in place for Commonwealth ISO use. e) Offeror/Contractor shall provide examples of monthly reporting. f) Offeror/Contractor shall provide examples of annual reporting. g) Offeror/Contractor shall define their continuous monitoring strategy, including measures, metrics and control assessments including frequencies. h) Offeror/Contractor shall provide examples of log review, contingency plan testing, incident response plan testing and vulnerability scans i) Offeror/Contractor shall describe responses to assessment findings,	
--	--	--	--

		threshold alerts, decisions to either mitigate, transfer, or accept risks related to identified vulnerabilities j) Offeror/Contractor shall describe method of access for all of the above.	
14	Data Segmentation Boundary Protection (ITP-SEC040 CSR-S2)	Offeror/Contractor shall provide a network/architecture diagram showing what security and technical controls are performing the network segmentation within the cloud service offering. • If solution spans more than one hosting environment (such as integration to Commonwealth managed environments, or across multiple hosting providers), provide details on what solution components and data are deployed in which environment.	

- Include border gateway, perimeter and/or network firewall, web application firewall, VPN tunnels, security zone access as applicable to the solution.
- Describe data encryption methods at rest and in transit across environments.
- Include the direction of connectivity (specify whether initiated inbound, outbound, or both) and specifications for API calls, protocols, etc.
- Estimated Transaction size, and frequency to be identified for each connection.

Offeror/Contractor shall describe how data segregation (physically or logically) of Commonwealth



Commonwealth data is segregated from non-Commonwealth data through logical isolation controls, including tenant-specific access restrictions, encryption, network segmentation, and audit

		data from non-Commonwealth data is guaranteed. Offeror/Contractor shall maintain the diagram throughout the contract term and provide updates if changes occur.	logging. Our solution relies on strong logical controls within a shared AWS-hosted environment.
15	Exploit and Malware Protection (ITP-SEC040 CSR-S3)	Offeror/Contractor shall provide and manage security controls. These are required to identify attacks, identify changes to files, protect against malware, protect user web services, Data Loss Prevention (DLP) and provide for forensic analysis. Offeror/Contractor shall describe which of these security controls are included in the proposed cloud service and how these additional controls would generate a notification to the Commonwealth. Please indicate if any are not used and also if any are used that are not listed below. ○ File Monitoring controls ○ Antivirus controls ○ Cloud Aware IDS/IPS ○ DLP controls ○ Forensic controls ○ Advanced Persistent Threat (APT) controls	File monitoring, antivirus, cloud-aware IDS/IPS, and forensic logging are included and generate security alerts through centralized monitoring and incident response workflows. DLP and dedicated APT-specific controls are not explicitly identified in the current design. Additional controls in use include WAF, MFA, RBAC, encryption, network segmentation, SIEM, and EDR.

16	Encryption (ITP-SEC040 CSR-S4)	Commonwealth policy requires the vendor to comply with SEC031, and SEC019 encryption policies and minimum standards with the proposed cloud service. Encryption technical controls are required to protect data in transit and data at rest. Link to SEC031 Encryption Standards Data in Transit Link to SEC019 Protection of Commonwealth Data Offeror/Contractor shall describe what encryption protocols are used to secure data in transit, file uploads or transfers. Offeror/Contractor shall describe what encryption technology is used for data at rest. Describe how those encryption keys are managed. Offeror/Contractor shall describe what encryption technology is used for data backup and recovery. Describe how those encryption keys are managed.	Encryption Protocols: The proposed cloud service uses TLS 1.3 over HTTPS for data in transit and supports SFTP and SCP for secure file uploads and transfers. Internal and administrative connectivity is further protected using OpenVPN and IPsec VPN, with encryption enforced for all sensitive transmission paths. Encryption Technology for Data at Rest: Data at rest is encrypted using AES-256, with encryption keys managed through AWS Key Management Service (KMS). Key access is restricted, lifecycle controls are enforced, and key management is separated from the data to reduce unauthorized access risk. Encryption Technology for Data Backup and Recovery: Backup and recovery data is encrypted using AES-256, with keys managed centrally through AWS KMS. Key access is restricted, key lifecycle controls are enforced, and encrypted backups are retained to support secure restoration during recovery operations. Encryption Technology for Databases: Databases are encrypted at rest using AES-256, with encryption keys managed centrally through AWS KMS. Database connections are protected with SSL/TLS, and key access is restricted and audited.
----	---------------------------------------	--	---

		If databases are used, describe what level of encryption is applied.	
17	Identity and Access Management (ITP-SEC040 CSR-S5)	Offeror/Contractor must provide technical controls for authenticating users, provisioning and deprovisioning users, identity interaction and nonrepudiation needs for admins, internet users, and internal users. Offeror/Contractor must describe reporting and audit mechanism for new staff, access changes, and deprovisioning of Offeror/Contractor staff. Offeror/Contractor must support use of Commonwealth Authentication services and Commonwealth Multi-Factor Authentication services. If cloud service is accessed by Commonwealth employees, Offeror/Contractor shall indicate if they can support Microsoft Azure Active Directory (AAD) or integration with ADFS. If cloud service is accessed by citizens or business partners, Offeror/Contractor shall indicate	Technical Controls for Users: Our service uses centralized identity and access management with MFA, RBAC, OAuth 2.0/OpenID Connect, unique named accounts, and automated provisioning/deprovisioning. Administrative, internet, and internal user actions are logged with timestamps and user attribution to support nonrepudiation, auditing, and immediate access revocation when no longer required. Reporting and Audit for Staff: We use a formal IAM audit trail showing who requested the change, who approved it, what access was granted or removed, when the change occurred, and which systems were affected. New user onboarding is reported through access request tickets and HR-triggered provisioning records. Access changes are captured in change logs and periodic access review reports. Deprovisioning is auditable through termination notices, account disablement logs, revocation confirmations, and post-removal validation reports. AAD/ADFS Support: Not included in our services. Authentication Methods: The company has a centralized identity and access management with unique user IDs, role-based access control, multi-factor authentication for all privileged and internet-facing access, and automated provisioning/deprovisioning tied to approved onboarding, role changes, and terminations. Administrative actions are performed through named accounts only and recorded in immutable audit logs to support nonrepudiation, accountability, and forensic review.

		if they can support use of Keystone Login. If Offeror/Contractor cannot support use of Commonwealth authentication methods, Offeror/Contractor shall describe the technical controls used for authenticating users, multifactor services, provisioning and deprovisioning users, identity interaction and nonrepudiation needs for admins, internet user, internal users, etc.	Access reviews, approval records, and deprovisioning confirmations shall be retained as audit evidence.
18	Vulnerability Assessment (ITP-SEC040 CSR-S6)	Offeror/Contractor shall conduct third-party independent security/vulnerability assessments on an annual basis. Offeror/Contractor shall describe its vulnerability assessment practices for the proposed cloud service and indicate how the	a) Cloud-hosted applications are developed with secure coding practices, reviewed before release, and scanned with automated vulnerability tools for application, infrastructure, and configuration weaknesses. Our company uses secure configuration, patch testing, SIEM, and application security assessments. b) We perform vulnerability assessments quarterly, and sooner after major changes or when compliance rules require it. Our

		following requirements will be addressed: a) Offeror/Contractor shall ensure cloud hosted application(s) are securely coded, vetted, and scanned. b) Offeror/Contractor shall conduct quarterly vulnerability assessments, or sooner if due to compliance regulations or other requirements, or upon a major change to the solution. c) Offeror/Contractor shall conduct a vulnerability assessment on an annual basis during the term of the contract and shall provide a copy of the results to the Commonwealth. (<i>Refer to ITP-SEC021 and ITP-SEC023 for guidance</i>) d) Offeror/Contractor shall be able to identify and validate vulnerabilities required for remediation and provide a mitigation plan and timeline to the Commonwealth.	quarterly scanning covers public-facing services, staging, production, and any newly deployed components. c) We complete an annual independent vulnerability assessment, and results are shared with the Commonwealth, including findings, severity, and remediation status. d) Identified vulnerabilities are validated through rescans or manual verification, then assigned a mitigation plan with owner, target date, and risk ranking. We provide the Commonwealth with the remediation timeline, compensating controls where needed, and closure evidence after fix verification. e) We maintain prompt patching with secure baseline configuration, testing before deployment, and automated patch management to keep systems current. Patching status is tracked as part of vulnerability remediation and included in reporting to the Commonwealth.
--	--	--	---

		e) Offeror/Contractor shall ensure patching is up to date.	
19	Data Protection Recovery (ITP-SEC040 CSR-S7)	Offeror/Contractor shall provide a business continuity plan that addresses the following (indicate N/A if not applicable to the proposed cloud service and/or if customer responsibility): ○ Data / Database Recovery ○ Application Recovery ○ Operating System Recovery ○ Infrastructure Recovery Offeror/Contractor shall describe its capability to do a complete restoration in the event of a disaster. Offeror/Contractor shall describe what tests are performed as part of its disaster recovery plan. Offeror/Contractor shall describe its capability to provide services during a pandemic event.	Business Continuity Plan: Our company uses automated backups, replication, and failover to support restoration of Commonwealth data and the hosted application, while the underlying AWS infrastructure remains provider managed. Data and database recovery and application recovery are addressed through regular backups, encrypted storage, and restore procedures; operating system recovery is largely the provider's responsibility in the managed cloud environment; and infrastructure recovery is supported through AWS regional redundancy and redeployment practices. Recovery objectives, testing, and restore validation is documented in the contract, including RTO/RPO targets and notification procedures for incidents and recovery events. Restoration After Disaster: Our service is designed for complete restoration through encrypted backups, application redeployment, and AWS-based infrastructure recovery. Recovery objectives and validation testing must be confirmed through documented disaster recovery procedures and periodic exercises. Tests After Disaster: The disaster recovery plan is tested annually and after material changes through tabletop exercises, partial restore tests, and

			full failover/failback exercises. Testing validates data recovery, application recovery, infrastructure recovery, communication procedures, and the ability of staff to execute the plan successfully. Services After Pandemic: Our company provides services after a pandemic by operating its cloud-based platform remotely, using redundant AWS infrastructure, automated backups, and secure remote access for support staff. This allows service delivery, monitoring, and recovery activities to continue even when employees cannot work on-site.
20	Compliance (ITP-SEC040 CSR-S8)	Offeror/Contractor shall describe its capability to meet compliance requirements if the proposed cloud service is subject to any regulations. At minimum, all offerings shall meet Commonwealth ITP requirements and NIST Moderate Level security controls specified in the Federal Information Processing Standards (FIPS) and Special Publications (SPs). NIST control enhancements shall also apply unless specified otherwise. The agency reserves the right to upgrade the NIST control level. The agency also reserves the right to mandate additional	Our service can support regulated workloads because it incorporates encryption, access control, audit logging, monitoring, and vulnerability management controls. Compliance with any specific law or regulation will depend on the Commonwealth's requirements, the data type involved, and the final contract terms, but the service is structured to provide the technical and operational controls needed for compliance.

		regulations or standards such as HIPAA, PCI, IRS, CMs/ARS, etc.	
21	Security Incident Handling (ITP-SEC040 CSR-S9)	Offeror/Contractor shall agree to monitor, prevent, and deter unauthorized system access as per the requirements outlined below and per the Requirement for Non-Commonwealth Hosted Applications/Services. Offeror/Contractor shall provide a copy of its customer facing Incident Response Plan (IRP). IRP should include incident handling practices, severity classification levels, customer notification and escalation processes, expected timeframes from time of impact to resolution, etc. • The Commonwealth will provide escalation contacts and resource account to be used for notification purposes.	Incident Response Plan: We maintain an incident response process that detects, triages, contains, eradicates, and recovers from security and service incidents using centralized monitoring, audit logging, and defined escalation paths. Incidents are classified by severity, with critical events receiving immediate response and Commonwealth notification, followed by regular status updates and a final report after resolution.
22	Inventory (ITP-SEC040 CSR-S10)	Offeror/Contractor shall describe how it maintains a complete, accurate, and up-to-date asset inventory of all resources involved in the proposed cloud service.	Asset Inventory: Our company maintains a complete, accurate, and up-to-date asset inventory through automated cloud discovery, standardized tagging, and periodic inventory reconciliation. Asset records are reviewed regularly and integrated with monitoring, vulnerability management, and incident response

		Offeror/Contractor shall provide a detailed asset inventory list, including country of origin, that will be used for the proposed cloud service offering. The Commonwealth reserves the right to prohibit use of certain hardware based on risk. Include manufacturer, model numbers, processors, disk drives, database hardware, data center networking components (routers, switches, etc.), security devices (firewalls, etc.), load balancers, and any other hardware relevant to the delivery of the service. Offeror/Contractor shall provide notice to the Commonwealth for any changes to the asset inventory used to support the cloud service being provided to the Commonwealth that would impact regulatory compliance (refer to REQ#5 Regulatory Compliance Verification)	processes to ensure all resources supporting the proposed cloud service remain accounted for throughout their lifecycle. Asset Inventory List: <table> <tr> <th>Asset class</th><th>Primary vendor / origin</th><th>Country of origin</th><th>Notes</th></tr> <tr> <td>Cloud compute hosts</td><td>Amazon Web Services</td><td>United States</td><td>Shared cloud infrastructure, not customer-owned hardware.</td></tr> <tr> <td>Object storage</td><td>Amazon Web Services</td><td>United States</td><td>Used for application data, archival, and recovery.</td></tr> <tr> <td>Managed database service</td><td>Amazon Web Services</td><td>United States</td><td>Database hosting and encryption at rest.</td></tr> <tr> <td>Load balancer / WAF</td><td>Amazon Web Services</td><td>United States</td><td>Protects web and API traffic.</td></tr> <tr> <td>Key management service</td><td>Amazon Web Services</td><td>United States</td><td>Central key lifecycle and access control.</td></tr> <tr> <td>Logging / SIEM stack</td><td>Mix of AWS-native and third-party tools</td><td>United States / TBD</td><td>Stores security and operational logs.</td></tr> <tr> <td>Endpoint/admin devices</td><td>TBD</td><td>TBD</td><td>Commonwealth-approved and inventoried separately.</td></tr> </table>	Asset class	Primary vendor / origin	Country of origin	Notes	Cloud compute hosts	Amazon Web Services	United States	Shared cloud infrastructure, not customer-owned hardware.	Object storage	Amazon Web Services	United States	Used for application data, archival, and recovery.	Managed database service	Amazon Web Services	United States	Database hosting and encryption at rest.	Load balancer / WAF	Amazon Web Services	United States	Protects web and API traffic.	Key management service	Amazon Web Services	United States	Central key lifecycle and access control.	Logging / SIEM stack	Mix of AWS-native and third-party tools	United States / TBD	Stores security and operational logs.	Endpoint/admin devices	TBD	TBD	Commonwealth-approved and inventoried separately.
Asset class	Primary vendor / origin	Country of origin	Notes																																
Cloud compute hosts	Amazon Web Services	United States	Shared cloud infrastructure, not customer-owned hardware.																																
Object storage	Amazon Web Services	United States	Used for application data, archival, and recovery.																																
Managed database service	Amazon Web Services	United States	Database hosting and encryption at rest.																																
Load balancer / WAF	Amazon Web Services	United States	Protects web and API traffic.																																
Key management service	Amazon Web Services	United States	Central key lifecycle and access control.																																
Logging / SIEM stack	Mix of AWS-native and third-party tools	United States / TBD	Stores security and operational logs.																																
Endpoint/admin devices	TBD	TBD	Commonwealth-approved and inventoried separately.																																

			<table> <tr> <td>Network security controls</td><td>Amazon Web Services / approved appliances</td><td>United States / TBD</td><td>Logical segmentation and secure access.</td></tr> <tr> <td>Backup and recovery storage</td><td>Amazon Web Services</td><td>United States</td><td>Retained per contract and legal requirements.</td></tr> </table>	Network security controls	Amazon Web Services / approved appliances	United States / TBD	Logical segmentation and secure access.	Backup and recovery storage	Amazon Web Services	United States	Retained per contract and legal requirements.
Network security controls	Amazon Web Services / approved appliances	United States / TBD	Logical segmentation and secure access.								
Backup and recovery storage	Amazon Web Services	United States	Retained per contract and legal requirements.								
23	Capacity (ITP-SEC040 CSR-I4)	Offeror or contractor shall provide capacity data associated with their offering. If metrics were provided by the agency, values should be based on those metrics. If exact numbers are not available, Offeror shall provide the following details: • Typical values for organizations of similar size and type (note any known deviations in the expected PA implementation). • Values for individual transactions and connections (ex: Each connection of type X consumes approximately 200 Kbps, or each	Capacity Data: Our cloud service is based on actual workload metrics provided by the Commonwealth where available. In the absence of agency-specific figures, the service uses SaaS values with elastic scaling, interactive sessions consuming roughly 100–300 Kbps, standard transactions averaging 5–25 KB, and batch processes executed hourly, nightly, weekly, or monthly depending on the business function.								

		transaction is approximately 5KB). For each of the above, provide details indicating whether such connections/transactions are batch processes (and expected/recommended intervals and run times) or not.	
24	Data Backup and Recovery (Hosting Terms)	Offeror/Contractor shall take all necessary measures to protect the data including, but not limited to, the backup of the servers on a daily and weekly basis in accordance with industry best practices and encryption techniques in accordance with Commonwealth retention requirements. Offeror/Contractor shall describe its backup and archival process including but not limited to the following: - What is the length of time backups are available? - Do you perform test restores? - What archival backup/restore/versioning is part of the agreement	Backup and Archival Process: Our company maintains encrypted backups with defined retention and archival periods, supports periodic test restores, and provides redundancy across U.S.-based repositories. Standard restores are included, while extended archival retrieval, historical version recovery, and special point-in-time restores may be subject to additional service fees if not covered by the contract. Backup encryption keys are managed separately under a controlled key management process with restricted access and audit logging.

		and what actions require any additional service fees? • Explain any shadowing or redundancy you have across multiple datacenters or repositories and if those data repositories are within the US and controlled by the vendor. • Is storage of backup media offsite provided? If so, for how long? • Location of backups and key management and storage for any backup encryption keys.	
--	--	---	--